

Case Study: MGM Resorts International Attack

George Rector

Old Dominion University

CS462

Susan Zehra

05/03/2026

MGM Resorts International

In September of 2023, MGM Resorts International was the victim of one of the most expensive cyberattacks in modern history. Slot machines and hotel keycards alike stopped working in an instant. Guests were standing in line at the front desk for hours, all while staff had to resort to old-school room assignments on paper in order to quell the unrest of well-paying customers. The cyberattack also shut down the ATMs of MGM, one of the most important aspects of MGM's revenue. This cyberattack lasted ten days and cost the company over 100 million dollars in revenue. This attack essentially forced one of the largest hospitality companies in the world to operate like they did in the 1980's. What is even more fascinating about this cyberattack is how it all started... A ten-minute phone call.

The group that claimed responsibility for the cyberattack called themselves the Scattered Spider. A loose confederation of mostly young, English-speaking hackers that coordinated with the ALPHV/BlackCat cybercriminal gangs. Scattered Spider focuses not on writing malicious malware, but on social engineering, more specifically vishing. They specifically target low level IT workers working at the help desk. According to security researchers working for Reuters, Scattered Spider found a low-level IT worker on LinkedIn and used their page to gather enough personal information about the worker to impersonate them. The group then called MGM IT help desk pretending to be the employee locked out of their account. (Satter & Bing, 2023). The help desk worker, doing what they are paid to do, reset the workers password and disabled MFA (Multi Factor Authentication), and that's it. No fancy exploits, no phishing emails, no malware injections. Just a friendly conversation with a coworker whose job is to help.

Once Scattered Spider was given access to the account, they first sought out to escalate their privileges. They used the original account to log into MGM's Okta management platform.

This platform performs like a control lever inside a company's network. It can change the privileges of any account on the network, including a god-mode privilege with unlimited powers. The attackers were able to trick Okta's virtual agent into granting unlimited power to the compromised account.

Once given the powers, the attackers moved into MGM's cloud environment. This environment housed almost all of MGM's operational infrastructure. This housed items like digital room keys, ATM operations, slot machine coordination, it even operated the elevators floor number display. Then they deployed the ransomware. As stated earlier, Scattered Spider didn't act alone. They used malware developed by ALPHV/BlackCat criminal groups. These groups create different high level malware applications that they in turn sell to the black market. Scattered Spider purchased this malware and started to deploy it.

Once the malware was deployed across all of MGM's networks across the world, the malware encrypted every file there was. This instantly shutdown MGM's entire network. Scattered Spider also stole six terabytes of data before deploying the malware. These files included names and personal details of millions of customers and workers alike. They contained emails from high level executives in the company, including the CEO (MGM Resorts International, 2023). This type of attack is called an exfiltration attack; steal the data you need and then deploy the malware. This attack is extremely dangerous because even if an affected company has good backups and refuses to pay a ransom to decrypt their files, the hackers can still extort the company, so the information stolen doesn't get released, its basically a double ransom.

MGM refused to pay the ransom. They learned from another attack on Caesars Entertainment a few weeks before. Cassars paid roughly 15 million dollars in ransoms to

Scattered Spider in order to decrypt their files, which in turn took a week to fully decrypt. After refusing, MGM and their IT department worked around the clock for ten days, rebuilding their system from the ground up from only a few backups they had saved. Once the IT workers validated the environments were safe, they slowly brought everything back online. During these ten days, MGM was strictly operated by pen and paper. Hotel room keys had to physically connect to the door instead of using the network to connect. Slot machines were run in a standalone mode, which turned customers to rival casinos in The Strip. Guests reported wait times upwards of eight hours for a room. This pressure cost MGM a lot of money quickly. When MGM disclosed their SEC filings later that year, they showed they lost upwards of 100 million dollars in revenue, plus another 10 million in consulting fees, legal expenses, and incident response costs (MGM Resorts International, 2023b). Insurance covered some of the cost, but not a lot. The company's stock price dropped 15% after the attack, making MGM lose around 850 million dollars in market value. MGM's stock price would take almost a year to fully recover.

Legal aftermath

Rebuilding the systems was only the tip of the iceberg for MGM. After the systems were fully operational again, multiple class action lawsuits were filed against MGM. These lawsuits were filed on behalf of the customers who had their personal data leaked publicly. They argued that MGM had failed to implement responsible security measures, especially around the help desk and identity verification procedures. Many of these lawsuits are still on going as of May 3, 2026, as well as many State Attorney Generals are investigating if MGM followed proper data breach protocols. (These protocols differ on a State-by-State basis but overall require companies to report to their residents that their personal data has been exposed within a specific time window).

Then came the part that made Executives everywhere nervous. In late 2023, the SEC enacted new cybersecurity disclosure laws. These laws required publicly traded companies to report any and all data lost due to a cyberattack within four days. Luckily for MGM, this rule was enacted mere days before the incident took place. But the timing of the attack made MGM a textbook example on why the SEC enacted this regulation in the first place. As of now, any publicly traded company that refuses to disclose cyber incidents can face fines, seizures, and in the case of executives, jail time.

Then came the law enforcement side of things. The FBI and international agencies made several arrests of alleged members of Scattered Spider. In January 2024, a 19-year-old kid was arrested in Florida. Additional arrests were made in the United Kingdom after the request of the FBI. But the frustrating reality with criminal groups like Scattered Spider is that they are decentralized. Unlike other “on the ground” criminal groups like gangs, cartels, and traffickers, which operate with an established hierarchy, cybercriminal groups work as a loose confederation of individuals, with no designated leader. Meaning even with these arrests in Florida and the UK, Scattered Spider is still operating today. This also makes the cybercriminals more vigilant and cautious in order not to be tracked down. But it also makes the next attack even more costly.

Attacks like these also give other cybercriminals a blueprint. Shortly after the MGM attack, security firms reported waves of copycat vishing attacks against IT help desks across multiple industries. Healthcare networks, financial service firms, and manufacturing companies alike. All of them were seeing the same pattern. A caller pretending to be an employee, asking for a password reset, disabling MFA, escalating their privilege once inside, stealing sensitive data, and then encrypting all of the remaining data. The MGM attack basically became a case study for other criminal groups to employ. CISA issued formal warnings to organizations

specifically about Scattered Spiders social engineering techniques, and recommended verification procedures (CISA, 2023).

Prevention

Hindsight is always 2020, and a simple identity verification process for the IT help desk would've prevented this attack. Organizations now require call-back procedures where help desk workers hang-up and call the employee directly to their personal cell phone to confirm identity before resetting credentials. Other companies have enacted video certification and biometric checks before resetting credentials. What's amazing about these new procedures is that none of them require fancy state-of-the-art security defenses, that cost millions to maintain. Just a simple 2-3 step guide in order to verify one's identity.

There is also a cultural fix needed as well. Help desks need to be treated as critical security infrastructure. This change, in my opinion, would help mitigate future incidents. If companies changed their hiring priorities, mandated training requirements, collection of performance metrics, and managerial oversight, we could see breaches such as MGMs as one off incidents. Most companies unfortunately see IT help desks as a customer service function, a department that is designed to be minimal cost on the company. But in reality, it needs to be the opposite.

Finally, the MGM attack is a solemn reminder that cybersecurity cannot be solved by technology alone. Their encryption was strong, their cloud provider was extremely reputable, Okta management is one of the best in the world. Yet none of that mattered because a friendly IT desk worker was just trying to help and do their job, and that will continue to always be the biggest vulnerability in cybersecurity. You.

References

Bond, S. (2023, October 6). MGM Resorts says cyberattack will cost casino giant \$100 million.

NPR. <https://www.npr.org/2023/10/06/1204232769/mgm-resorts-cyberattack-100-million>

CISA. (2023, November 16). *Scattered Spider advisory* (Cybersecurity Advisory AA23-320A).

Cybersecurity and Infrastructure Security Agency.

<https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-320a>

MGM Resorts International. (2023, October 5). *Notice of cybersecurity issue* [Press release].

<https://www.mgmresorts.com/en/news.html>

Satter, R., & Bing, C. (2023, September 13). MGM hackers broke in via vishing call to IT help desk, sources say. *Reuters*. [https://www.reuters.com/technology/cybersecurity/mgm-hackers-](https://www.reuters.com/technology/cybersecurity/mgm-hackers-broke-via-vishing-call-it-help-desk-sources-say-2023-09-13/)

[broke-via-vishing-call-it-help-desk-sources-say-2023-09-13/](https://www.reuters.com/technology/cybersecurity/mgm-hackers-broke-via-vishing-call-it-help-desk-sources-say-2023-09-13/)